



CLOUD
Summit 2026
臺灣雲端大會

AI與資安的完美結合-探索雲端機密運算的奧妙

林家瑋 (Ray Lin), CISO / CAIO, AWS Security Hero



CLOUD
Summit 2026
臺灣雲端大會

ORGANIZED BY
iThome

林家瑋 (Ray Lin), ray.lin@ifus.tw



- 全球首批 GCR首位 AWS Security Hero
- iFUS System Consultants Ltd. – CISO / CAIO
- DataBrushing.ai (QSP) – CDO
- 寓意科技(fable) – 資安顧問總監
- 全智網科技(AI Network) – AWS Champion授權講師 / ISC2授權講師
- 長宏專案(PM-ABC) – PMI授權培訓講師
- PMI Taiwan獎項辦公室(PTGA) – 執行長
- ISC2 Taipei Chapter – 理事 / 媒體公關委員會 主委
- AWS User Group DevSecOps Taiwan – 共同創辦人
- 登豐數位、鑑智實相、捷虹資訊、德慎精算、睿峯管顧 – 顧問 / 講師
- 曾服務於美商、日商、新創、上市櫃、跨國集團；曾任CEO、COO、產品暨IT主管、業務主管、資深SI工程師與資深PG
- 曾獲台灣發明家創意獎、ISC2國際資安新星專家獎、PMI-TW優良志工獎 / 績優執行理監事、翻譯出版7本知名敏捷書籍

| 巨匠電腦 – SSDLC資安講師

| 台灣數位安全聯盟(TWCSA) – 理事

| DevSecOps Taiwan – 社長



資料加密做得很全面，百毒不侵？



我們公司保護資料
都用最高規格
AES-256
TLS1.3
KMS



那...資料在
RAM
的時候呢？

資料狀態(Data State)

- 資料三態
 - 靜態(Data at Rest)：資料躺在載體 > 也會被偷
 - 傳輸(Data in Transit)：資料移動路上 > 還被攔截
 - 使用(Data in Use)：資料載入使用 > 最常忽略





使用(Data in Use) - 安全風險

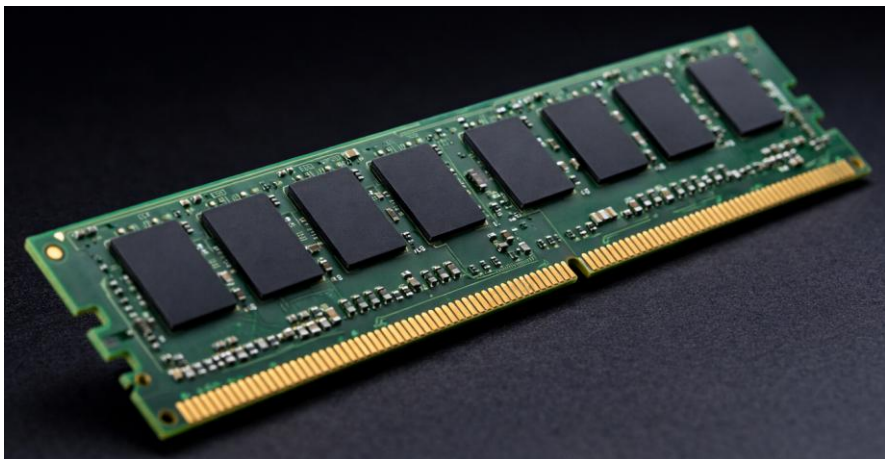
- 載入使用 最常忽略
 - 資料一進記憶體就明文
 - OS管理者、雲端管理者「理論上看得到」
 - Debug / Crash Log洩漏
- 安全風險
 - **Memory Dump** : Key、Token、PII、模型權重都在裡面，通常沒加密、權限控管鬆散
 - **Rowhammer** : 一種對DRAM的攻擊方法
 - **Side-channel(Cache Timing)** : 用「時間、耗電、快取行為」推測機密
 - 惡意Library / Injection





Rowhammer

- Rowhammer：利用DRAM運行過程中產生的意外電荷洩漏效應，在極短時間內反覆存取同一記憶體列，就能讓它的隔壁造成位元翻轉(bit flip)，最快109秒取得系統控制權



```
PPPPPP HH HH 00000 EEEEEEE NN NN IIIII XX XX
PP PP HH HH 00 00 EE NNN NN III XX XX
PPPPPP HHHHHHH 00 00 EEEEE NN N NN III XXXX
PP HH HH 00 00 EE NN NNN III XX XX
PP HH HH 00000 EEEEEEE NN NN IIIII XX XX
by COMSEC, ETH Zurich
```

```
[+] Allocating 4MiB contiguous memory blocks.
```

```
*** ATTACK TRY #1 ***
```

```
[+] Templating memory for Rowhammer bit flips...
```

```
[+] Found 5 repeatable and exploitable bit flips.
```

```
[+] Testing bitflip @ 0x100242580.
```

```
[+] Massaging memory using Rubicon primitives.
```

```
[+] Spraying page tables (base = 0x200000000, limit = 63000).
```

```
[+] Trying to retrigger the bit flip by hammering pattern for 20480K times.
```

```
[+] R/W primitive achieved! Trying to find and manipulate the process' cred struct now.
```

```
[+] Searching for struct cred of our process (uid=0, gid=0) in physical memory...
```

```
[+] Searching within 511x 4K pages at physical address 0x100000000.
```

```
[!] ATTACK SUCCEEDED ~ Got root shell!
```

```
root@ee-tik-cn130:/tmp/pjattke/ddr5-utrr-syslevel# |
```

什麼是機密運算

- 機密運算(Confidential Computing)
 - 保護「使用中資料」，補上傳統「靜態資料」與「傳輸資料」的缺口
 - 資料一旦進入CPU/Memory進行處理，通常會變成明文
 - 在硬體式、可證明的TEE(Trusted Execution Environment)內執行運算
 - 處理高度敏感的資料類型，如PII、PHI、PFI及IP
 - 適用於金融、醫療、AI模型訓練與區塊鏈錢包等領域



✓ 要防的對象

Cloud Operator / Host Admin

雲端或主機層高權限
操作人員

Hypervisor / Host OS

虛擬化層或主機層
存取風險

惡意管理流程

Debug、Dump、
Snapshot、維運工具
濫用

多方資料合作

多方共同運算但不想
互相揭露原始資料

⚠ 不保證防的對象

應用程式本身的漏洞

SQL Injection、RCE、
邏輯錯誤等

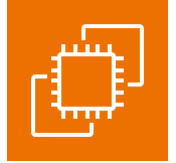
資料離開TEE後的濫用

輸出結果若洩漏太多
資訊，仍要做資料最
小化與隱私設計

Side-Channel攻擊

可降低風險，但非完全消除

AWS Nitro System



AWS Nitro System

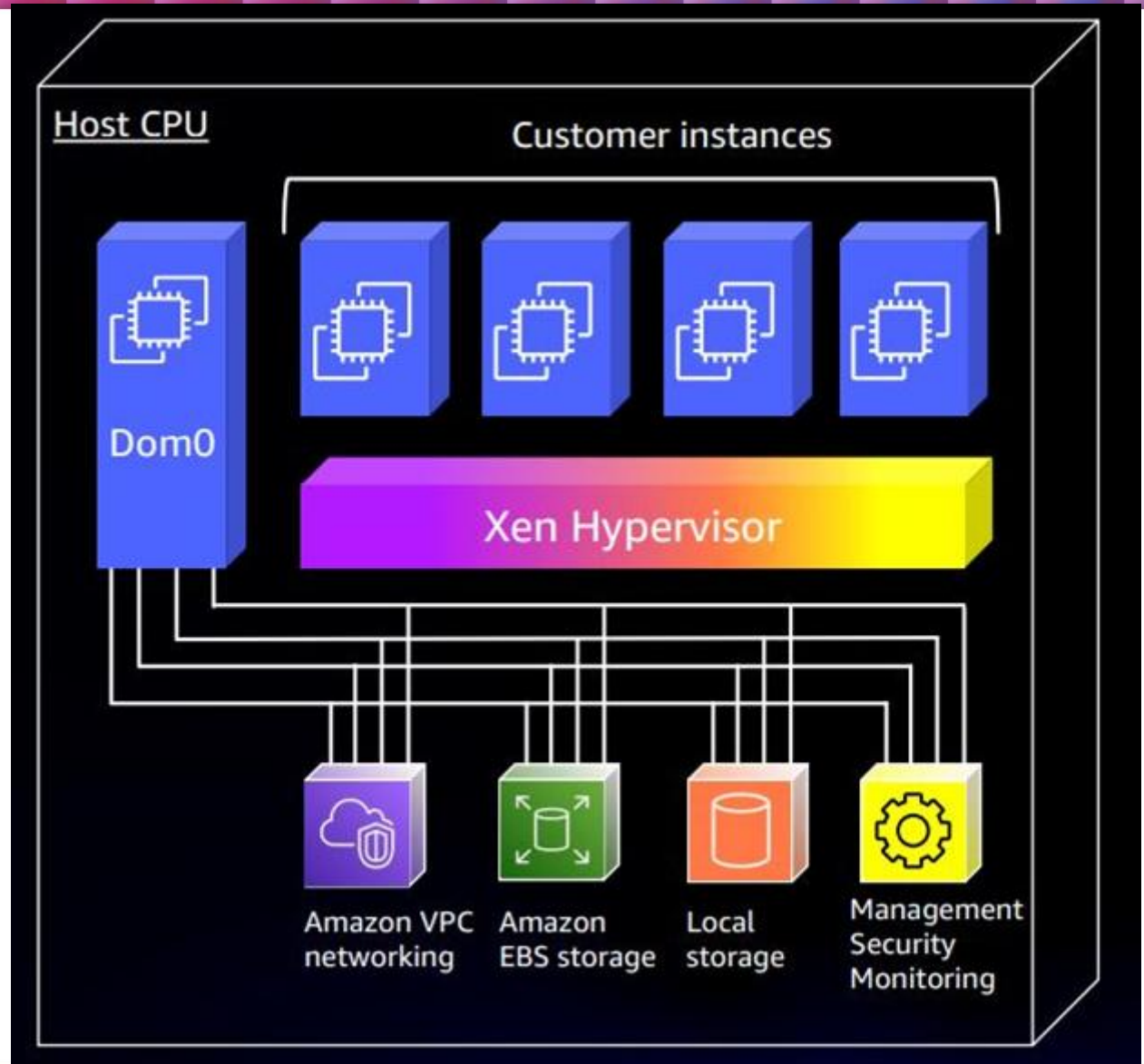
- AWS Nitro系統重新定義虛擬化架構，把管理與I/O處理功能從主機移到專用硬體設備，帶來更高效能、更安全的隔離環境，其核心如下：
 - **Nitro Cards**：包括一系列專用硬體卡片，像是VPC、EBS、Instance store、加密、安全監控等I/O功能，減輕主機負擔並提升效能
 - **Nitro Security Chip**：負責硬體層級包括安全啟動、Instance隔離，確保沒有人(包含AWS員工)能存取實體伺服器資料
 - **NitroTPM**：符合TPM 2.0規格，可在EC2 Instance提供硬體級別的TPM功能，用於金鑰處理(建立、儲存與使用)與完整性驗證等
 - **Nitro Hypervisor**：輕量級Hypervisor，只處理CPU和記憶體(效能近似裸機)

✔ AWS機密運算是從EC2底層架構開始設計的信任鏈

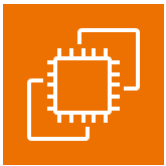
Before Nitro



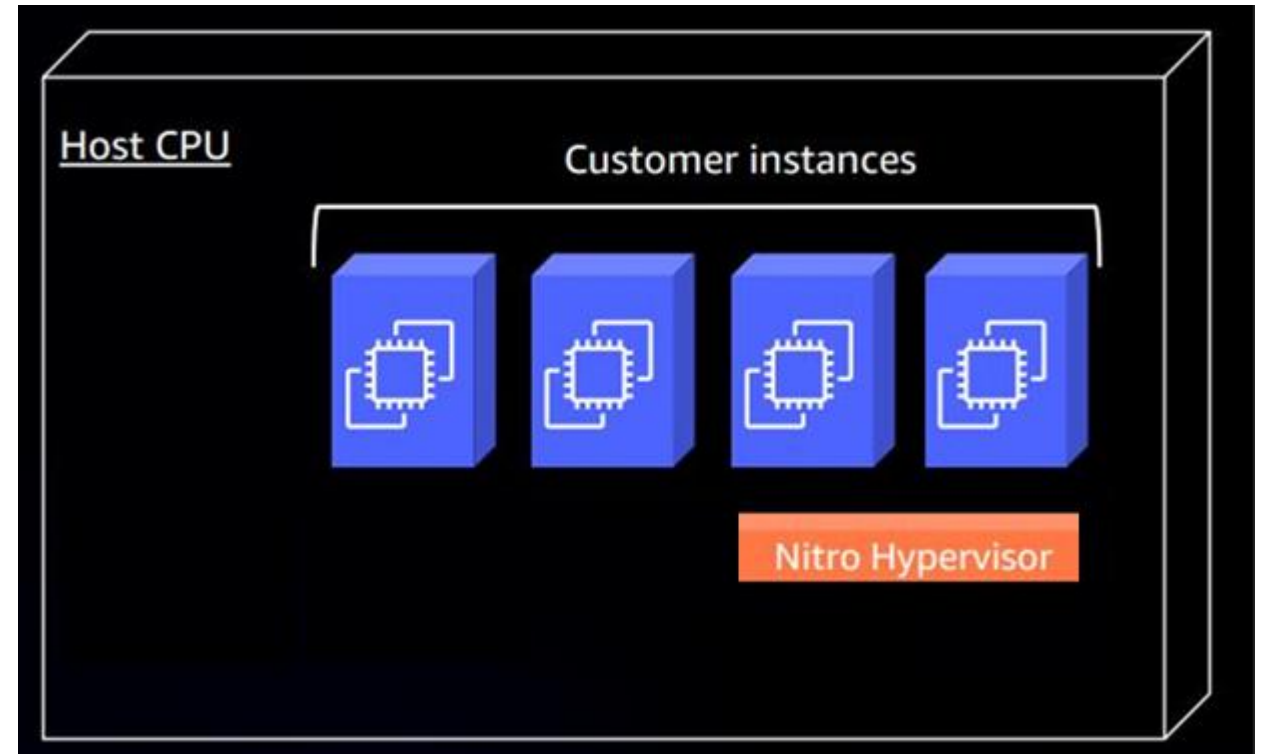
Source: [STH](#)



AWS Nitro System



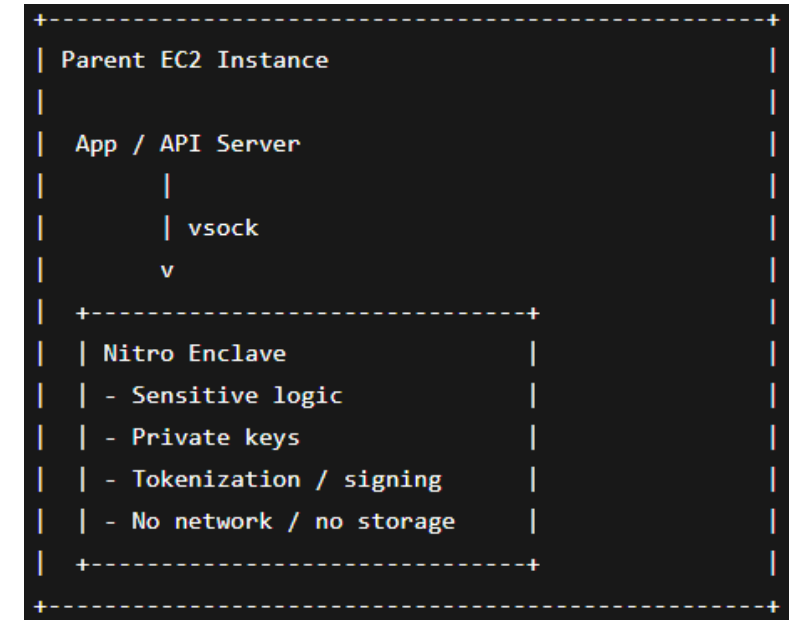
AWS Nitro System



Source: [STH](#)

AWS Nitro Enclaves

- **AWS Nitro Enclaves**是在EC2 Instance切出更小的信任邊界(隔離執行環境)
- Enclaves是獨立的、強化的和高度受限的虛擬機器
- Parent Instance僅能以Secure Local Socket連接Enclaves，其Process、Apps、Kernel或Users均無法存取Enclave內容
- 可整合
 - **AWS KMS**：加解密與金鑰生命週期管理
 - **ACM(AWS Certificate Manager)**：SSL/TLS憑證
 - **CloudTrail**：追蹤所有使用者活動和API行為



AWS Nitro Enclaves

- 沒有持久性儲存、互動式存取或外部網路連接、無法SSH進入Enclave
- Enclave內的資料和應用程式無法被Parent Instance的處理程序或使用者(root或管理員)存取，只有授權的程式碼能在Enclaves執行
- 所以
 - 秘密只在Enclave內短暫存在
 - 就算Parent instance被拿到root，也讀不到Enclave記憶體
 - 可以把“最敏感的那一段”抽出來放Enclave處理(金鑰/PII解密/簽章/推論)



AWS Nitro Enclaves

AWS機密運算的四個基礎元件



TEE(Trusted Execution Environment)

把敏感運算關進硬體保護的隔離房間



Measurement

確認房間裡跑的是哪一份程式碼的指紋(衡量值)



Attestation

讓外部服務相信這個環境是真實且可信的



Key Release

只有通過證明的程式碼才能取得解密能力



流程：Attestation + KMS Key Release



Enclave啟動

產生
attestation

KMS驗證

以公鑰回應

⚠ 傳統KMS：IAM principal可解密

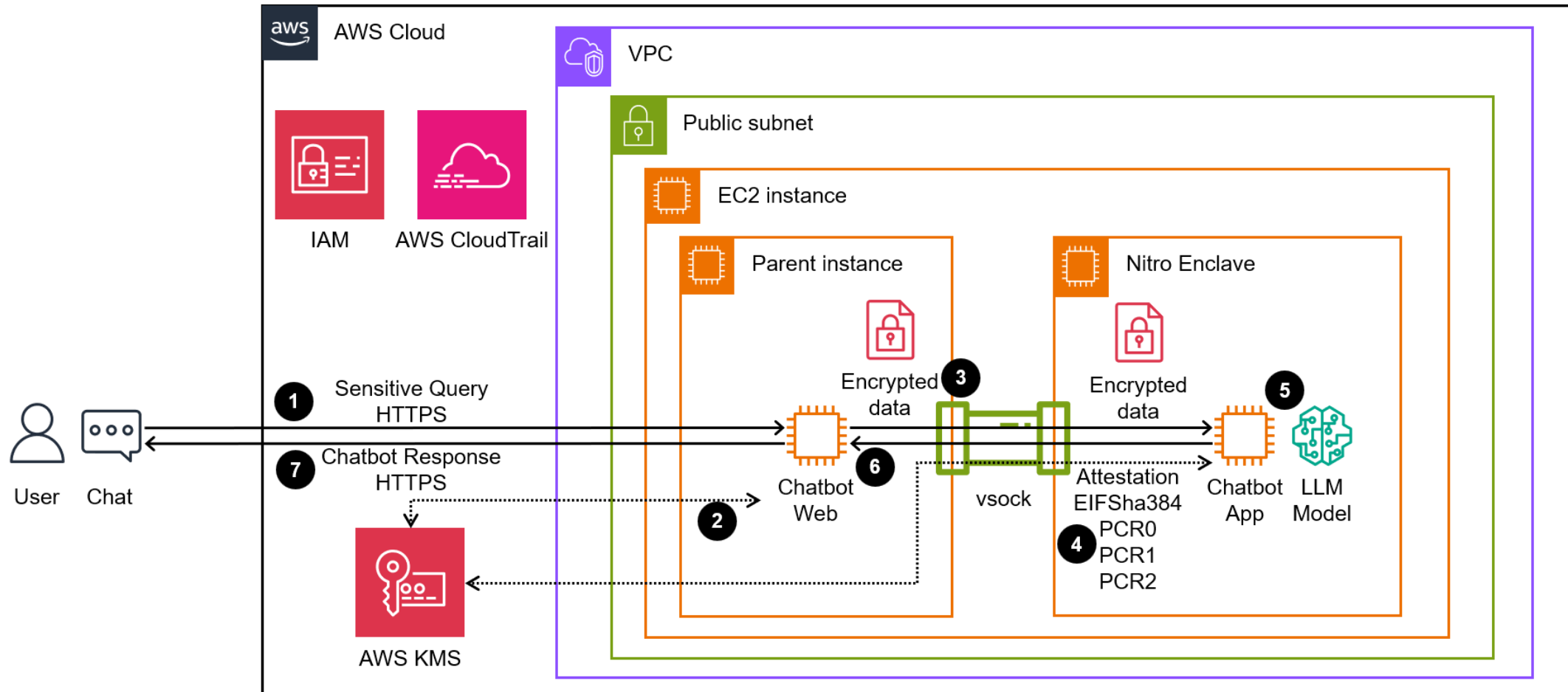
✅ 機密運算：通過證明的程式碼與執行環境才可解密

AWS Nitro Enclaves需求

- **Parent Instance**需求：
 - 基於Nitro的Instance
 - 具有至少4個vCPUs的Intel或AMD型Instance
 - 具有至少2個vCPUs的AWS Graviton型Instance
 - 但並非支援所有Instance，支援清單請參閱
 - **Linux或Windows** (2016或更新版本)作業系統
- **Enclave**需求：**Linux**作業系統
- 安裝、設定與執行的具體步驟GitHub(包括今日簡報下載)
https://github.com/cheng-ruru/AWS_NitroEnclaves



利用Nitro Enclaves來保護LLM推論



PCR(Platform Configuration Register)

- PCR代表什麼

- **PCR0** : EIF(Enclave Image File)的量測值
- **PCR1** : Linux Kernel與啟動程式(Bootstrap)的量測值
- **PCR2** : 應用程式的量測值
- PCR3 : 指派給Parent Instance的IAM Role的量測值
- PCR4 : Parent Instance ID的量測值
- PCR8 : Enclave映像檔簽署憑證的量測值

```
"Measurements": {  
  "HashAlgorithm": "Sha384 { ... }",  
  "PCR0": "d5b88c7aedaf4840328dfb99520b671e70fbc17a39230504f96114bea7a65e318f8e48590f7d83a9b47a059af2877c52",  
  "PCR1": "3b4a7e1b5f13c5a1000b3ed32ef8995ee13e9876329f9bc72650b918329ef9cf4e2e4d1e1e37375dab0ba56ba0974d03",  
  "PCR2": "bf8ac249faf71fbf017f0a52e84f9a3242906fe66a17b9b3220e8bfbf9c747f5ad3617f7bb059ce584167f92177d0bbf"
```



AWS的機密運算觀點

Azure / GCP

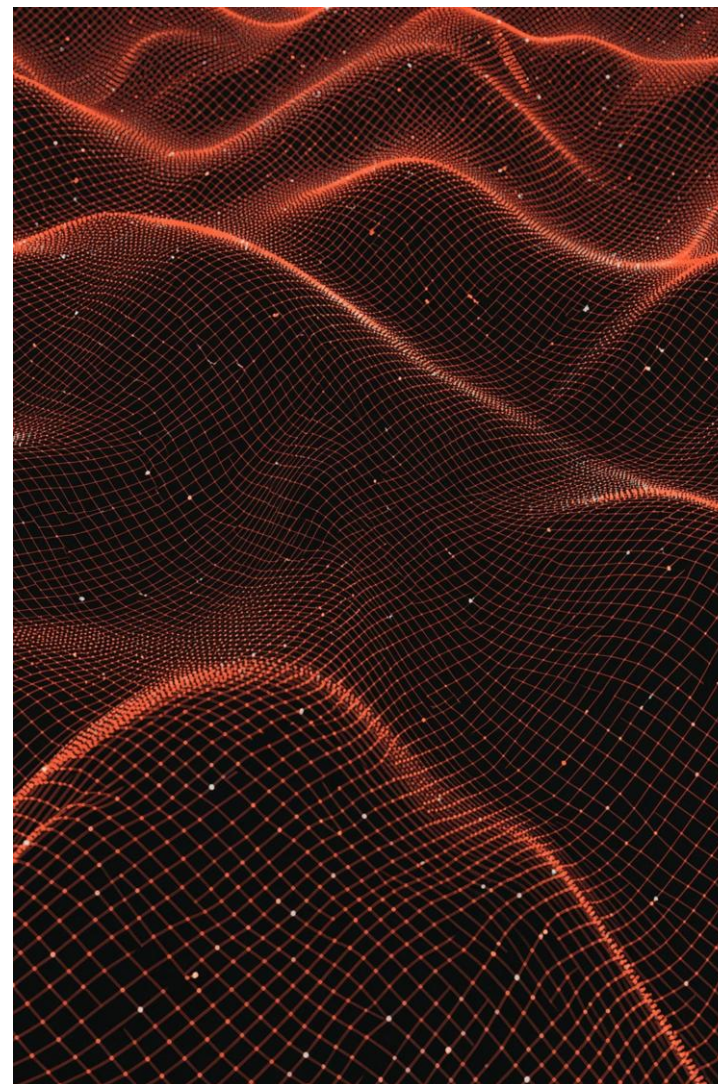
通常從「啟用Confidential VM」開始
強調負載平移(Lift and Shift)的便利性

AWS

從Nitro System底層隔離設計出發
再依需求選擇Enclave(應用層隔離)或SEV-SNP(VM記憶體加密)

Always-On基礎保護

Nitro-based EC2提供「always-on」基礎保護
且沒有AWS operator能存取客戶EC2內容的機制





核心 ID | 資訊

選取



Nitro Enclave | 資訊

啟用



選取

啟用



停用



CPU 選項 | 資訊

為執行個體設定 CPU，以最佳化效能並節省授權成本。

☒ 使用預設 CPU 選項

☐ 指定 CPU 選項

預設作用中 vCPU

2

vCPU 總數

2

Azure機密運算



Confidential VM

AMD SEV-SNP或Intel TDX，偏向**負載平移 (Lift and Shift)**，通常不需改程式



Confidential Containers / AKS

容器層級完整性與Attestation Policy



Intel SGX

Application Enclave，信任邊界更小，通常
需要應用調整



Confidential GPU VM

適合AI/ML加速與敏感資料處理



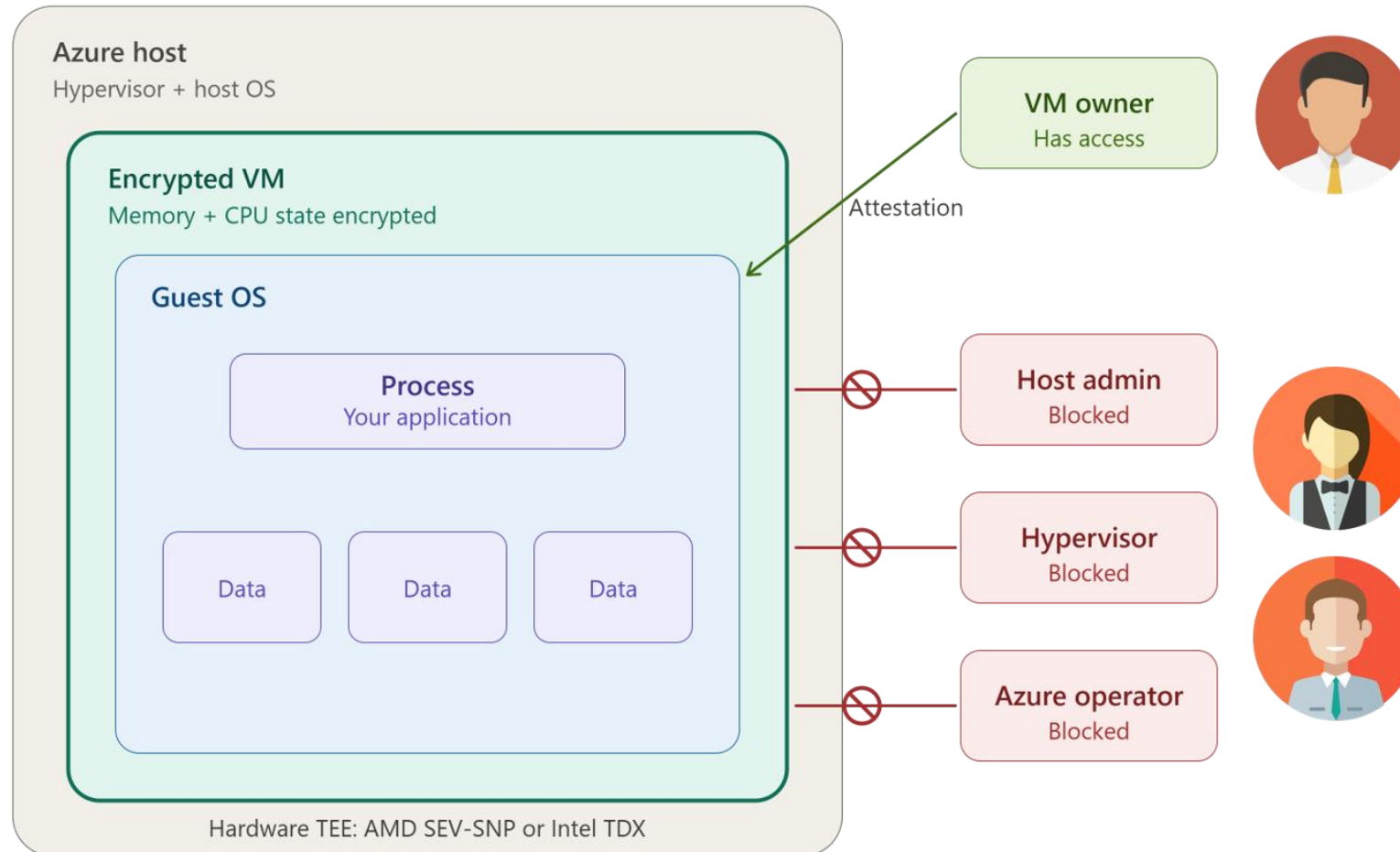
Azure Attestation

Microsoft提供的遠端證明服務



AMD SEV-SNP與Intel TDX可讓hypervisor、host management code與管理員無法直接檢視或修改confidential VM的memory或CPU state

Azure Confidential VM





首頁 > 計算基礎結構 | 虛擬機器

建立虛擬機器

...



協助我為工作負載選擇正確的 VM 大小

協助我建立低成本的 VM

協助我建立針對高可用性最佳化的 VM

區域 * ⓘ

(Asia Pacific) Japan East



部署到 Azure 擴充區域

可用性選項 ⓘ

可用性區域



區域選項 ⓘ

標準

虛擬機器的基本安全性層級。

信任的啟動虛擬機器

透過安全開機和虛擬信任平台模組 (vTPM) 等可設定的功能，在 Gen 2 虛擬機器上抵禦持續和進階攻擊。

機密虛擬機器

在可信啟動上，機密虛擬機器利用以硬體為基礎的信任執行環境，保證提供更高的機密性和完整性。

機密虛擬機器



設定安全性功能

安全性類型 ⓘ

影像 * ⓘ

Windows Server 2025 Datacenter Server Core - x64 第 2 代



查看所有映像 | 設定 VM 世代

GCP機密運算

NVIDIA Confidential Computing on H100 GPU

將TEE延伸到GPU，適合AI/ML加速工作負載

Confidential Space

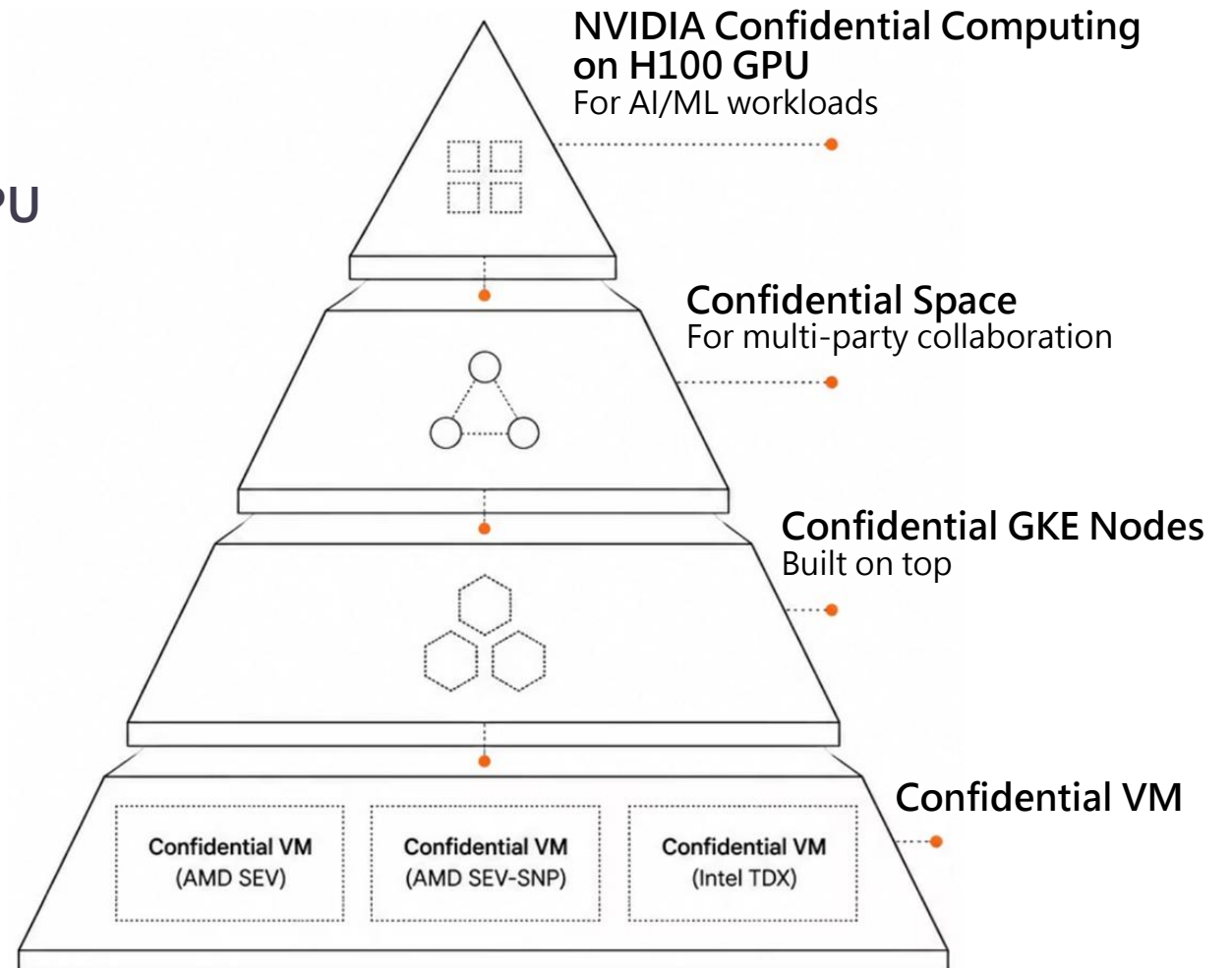
多方資料合作，保留資料機密性與所有權

Confidential GKE Nodes

強制GKE node使用Confidential VM

Confidential VM

支援AMD SEV、AMD SEV-SNP、Intel TDX





Google Cloud

WordPress

搜尋資源、文件、產品和其他項目 (請按 / 鍵)

搜尋

1

← 建立執行個體 VM 建立位置...

- 機器設定
e2-medium, us-central1
- OS 和儲存空間
Debian GNU/Linux 12 (bookworm)
- 資料保護
快照排程
- 網路
1 個網路介面
- 觀測能力
安裝作業套件代理程式
- 安全性**
- 進階

安全性

身分及 API 存取權

服務帳戶

Compute Engine default service account

如要透過這個服務帳戶存取執行個體，請新增服務帳戶使用者角色：roles/iam.serviceAccountUser。瞭解詳情

存取權範圍

☒ 允許預設存取權

☐ 允許所有 Cloud API 的完整存取權

☐ 分別為每個 API 設定存取權

機密 VM 服務

這個 VM 執行個體已停用機密運算功能

啟用

受防護的 VM

啟用所有安全程度最高的設定。

☐ 啟用安全啟動功能

☒ 啟用 vTPM

☒ 啟用完整性監控功能

要啟用機密運算功能嗎？

如要啟用機密運算，系統會將 VM 設定更新為這些相容值。您也可以返回主頁面時調整這些設定。瞭解詳情

機密 VM 服務

請選取類型

AMD SEV-SNP

確保資料和程式碼的機密性與完整性。Learn more

	Existing configuration	Updated configuration
機器家族	E2	N2D
機型	e2-medium	n2d-standard-2
CPU 平台	Automatic 以上版本	Automatic 以上版本
區域和可用區	us-central1	us-central1-a
網路卡		gVNIC
Boot disk image	Debian GNU/Linux 12 (bookworm)	Confidential image (Ubuntu 24.04 LTS NVIDIA version: 580)

取消 確認

三雲機密運算比較

平台	定位	代表能力	是否收費	主要強項	適合場景
AWS	金鑰與敏感資料保險箱	Nitro System Nitro Enclaves NitroTPM KMS Cryptographic Attestation EC2 AMD SEV-SNP	無額外費用	讓通過驗證的工作負載，才能使用金鑰	私鑰保護 數位簽章 Tokenization 敏感資料解密
Azure	企業機密運算工具箱	Confidential VM AMD SEV-SNP Intel TDX Intel SGX AKS Confidential Containers Confidential GPU	無額外費用	VM、容器、GPU等 企業導入選項完整	政府 金融 醫療 企業系統 既有VM搬遷
GCP	AI與資料合作安全空間	Confidential VM Confidential Space Confidential GKE Nodes NVIDIA H100 Confidential GPU	<u>額外收費</u>	多方資料合作與 AI/GPU機密運算	AI/ML 資料聯盟 跨組織分析 隱私保護資料合作



CLOUD
Summit 2026
臺灣雲端大會

ORGANIZED BY
iThome

DevSecOps Taiwan



林家瑋|大Ray@DevSecOps社長

DevSecOps Taiwan (2500+)



https://bit.ly/AG3_DevSecOps



- 每個月免費線上分享
 - 每月固定一場 👉 1~2小時分享
 - 不定期快閃 👉 0.5~1小時分享
- 社群分享主題與交流方向
 1. Agile / Waterfall / Hybrid
 2. DevSecOps (DevOps + Security)
 3. Secure Coding
 4. AI Security
 5. Cybersecurity
 6. Cloud Security (AWS / Azure / GCP)



歡迎加我好友



Email: ray.lin@ifus.tw